IS Auditing Process

Arrianto Mukti Wibowo, CISA

amwibowo@makarauiconsulting.com

+62-856-8012508

2005

Sebagian besar dari
CISA Review Manual

Agenda

- Organization of the IS Audit Function
- IS Audit Resource Management
- Audit Planning
- Laws and regulations
- ISACA standards and guidelines for IS auditing
- Risk analysis
- Internal controls
- Performing an IS audit
- Control self assessment
- Corporate governance

Process Area Objective

- Ensure that the CISA candidate…
- "The objective of the process area is to ensure that the CISA candidate *has the knowledge necessary to plan and conduct IS audits in accordance with generally accepted IS audit standards and guidelines to provide a statement of assurance (audit report) that the organization's business processes supported by information technology are controlled, monitored and adequately assessed*. "

Audit Planning (1)

Harus secara jelas menjelaskan :

1. Tujuan audit.
2. Kewenangan auditor.
3. Adanya persetujuan top-management.
4. Metode audit.

Audit Mission and Planning

- Yang harus dilakukan sebelum melakukan audit
  1. Memahami keadaan bisnis dari subjek audit:business' mission, business' objectives, business' processes, information and processing requirements such as availability, integrity, security dan *information architecture requirements*. Termasuk pula proses dan teknologi
  2. Melakukan analisa resiko.
  3. Mengevaluasi kendali internal.
  4. Menetapkan tujuan dan ruang lingkup audit
  5. Menentukan strategi dan pendekatan audit
  6. Menetapkan sumber daya yang diperlukan untuk proses audit

Audit Planning (2)

Seorang auditor harus bisa mendapatkan pemahaman terhadap apa yang sedang diaudit: environment, sistem informasi, operasi, dsb.

Audit Planning (3)

Untuk memahami organisasi, seorang auditor dapat melakukan :

1. Tour keliling fasilitas-fasilitas organisasi.
2. Membaca laporan tahunan, media industri ybs, atau analisis keuangan independen.
3. Membaca strategic plan & business plan.

Audit Planning (4)

4. Interview key managers.
5. Memperhatikan peraturan perundang-undangan yang berlaku untuk organisasi itu. Lihat SARBANES-OXLEY ACT 2002
6. Membaca laporan-laporan sebelumnya.

Case Study: Dokumen Yang Dibutuhkan Pra-pekerjaan

- Company profile
- Struktur organisasi & tugas
- Deskripsi layanan
- Dok proses bisnis
- Rencana jangka pendek, menengah & panjang perusahaan
- Hasil audit sebelumnya
- Daftar aturan-aturan pemerintah/luar yang mempengaruhi PT.XYZ
- Dok kebijakan akuntansi perusahaan
- Dokumen-dokumen yang terkait kebijakan keamanan perusahaan
- Dokumen daftar aplikasi PT.XYZ, berikut dokumentasinya
- *Non-disclosure agreement* akan ditandatangani.

Laws and Regulations

- Regulatory requirements
  - Establishment
  - Organization
  - Responsibilities
  - Correlation to financial, operational and IT audit functions

Laws and Regulations

- Steps to determine compliance with external requirements:
  - Identify external requirements
  - Document pertinent laws and regulations
  - Assess whether management and the IS function have considered the relevant external requirements
  - Review internal IS department documents that address adherence to applicable laws
  - Determine adherence to established procedures

ISACA Standards and Guidelines for IS Auditing

- ISACA IS Auditing Standards
- ISACA IS Auditing Guidelines
- ISACA IS Auditing Procedures

Standar for IS Auditing (1)

Tujuan adanya standar :

- Batas minimum dari kinerja auditor.
- Memberikan gambaran terhadap ekspektasi yang seharusnya ada pada manager.

Standar for IS Auditing (2)

Standar ISACA :

1. Audit Charter.
    1. Responsibility, Authority & Accountability.
2. Independence.
    1. Professional Independence.
    2. Organizational Relationship.
3. Professional Ethics & Standards.
    1. Code of Professional Ethics.
    2. Due Professional Care: kehati-hatian.

Standar for IS Auditing (3)

4. Competence
    1. Skills & Knowledge
    2. Continuing Professional Education
5. Planning
    1. Audit planning
6. Performance of Audit Work
    1. Supervision: audit staff harus diawasi
    2. Evidence

Standar for IS Auditing (4)

7. Reporting
    1. Report Content & Form
8. Follow-up Activities
    1. Follow-up

ISACA Guidelines for IS Auditing

- Use of ISACA Guidelines
  - Consider the guidelines in determining how to implement the standards
  - Use professional judgment in applying these guidelines
  - Be able to justify any departure

ISACA Guidelines

- G1 Using the Work of Other Auditors
- G2 Audit Evidence Requirement
- G3 Use of Computer Assisted Audit Techniques (CAATs)
- G4 Outsourcing of IS Activities to Other Organisations
- G5 Audit Charter
- G6 Materiality Concepts for Auditing Information Systems
- G7 Due Professional Care
- G8 Audit Documentation
- G9 Audit Considerations for Irregularities
- G10 Audit Sampling
- G11 Effect of Pervasive IS Controls
- G12 Organisational Relationship and Independence
- G13 Use of Risk Assessment in Audit Planning
- G14 Application Systems Review
- G15 Planning Revised
- G16 Effect of Third Parties on an Organisation's IT Controls
- G17 Effect of Nonaudit Role on the IS Auditor's Independence
- G18 IT Governance
- G19 Irregularities and Illegal Acts
- G20 Reporting
- G21 Enterprise Resource Planning (ERP) Systems Review
- G22 Business-to-consumer (B2C) E-commerce Review
- G23 System Development Life Cycle (SDLC) Review Reviews
- G24 Internet Banking
- G25 Review of Virtual Private Networks
- G26 Business Process Reengineering (BPR) Project Reviews
- G27 Mobile Computing
- G28 Computer Forensics
- G29 Post-implementation Review
- G30 Competence
- G31 Privacy 1

G2 Audit Evidence Requirement

1. BACKGROUND

1.1 Linkage to Standards

1.1.1 Standard S6 Performance of Audit Work states "During the course of the audit, the IS auditor should obtain sufficient, reliable and relevant evidence to achieve the audit objectives. The audit findings and conclusions are to be supported by appropriate analysis and interpretation of this evidence."

1.2 Need for Guideline

1.2.1 The purpose of this guideline is to define the word "evidence" as used in standard S6 of the IS Auditing Standards and to address the type and sufficiency of audit evidence used in information systems auditing.

1.2.2 This guideline provides guidance in applying IS auditing standards. The IS auditor should consider it in determining how to achieve implementation of the above standard, use professional judgment in its application and be prepared to justify any departure.

2. PLANNING

2.1 Types of Audit Evidence

2.1.1 When planning the IS audit work, the IS auditor should take into account the type of audit evidence to be gathered, its use as audit evidence to meet audit objectives, and its varying levels of reliability. Among the things to be considered are the independence and qualifications of the provider of the audit evidence. For example, corroborative audit evidence from an independent third party can be more reliable than audit evidence from the organisation being audited. Physical audit evidence is generally more reliable than the representations of an individual.

2.1.2 The various types of audit evidence which the IS auditor should consider using include:

- Observed processes and existence of physical items
- Documentary audit evidence
- Representations
- Analysis

2.1.3 Observed processes and existence of physical items can include observations of activities, property and information systems

Relationship between standard & guideline

Cross-reference		Standards							
		S1	S2	S3	S4	S5	S6	S7	S8
Guidelines	G1						X		
	G2						X		
	G3			X		X	X		
	G4	X				X	X		
	G5	X							
	G6					X			
	G7			X					
	G8						X	X	
	G9			X					
	G10						X		
	G11						X		
	G12		X	X					
	G13					X	X		
	G14						X		
	G15					X			
	G16					X	X		
	G17		X				X		
	G18						X		
	G19			X		X	X	X	
	G20							X	
	G21		X				X		
	G22						X		
	G23						X		
	G24		X		X	X	X		
	G25						X		
	G26						X		
	G27	X			X	X	X		
	G28			X	X	X	X		
	G29						X		X
	G30				X				
	G31	X				X	X		

ISACA Procedures for IS Auditing

- Use of ISACA Procedures
  - Procedures developed by the ISACA Standards Board provide examples.
  - The IS auditor should apply their own professional judgment to the specific circumstances.

ISACA Procedures

P1 IS Risk Assessment

P2 Digital Signatures

P3 Intrusion Detection

P4 Viruses and other Malicious COde

P5 Control Risk Self-assessment

P6 Firewalls

P7 Irregularities and Illegal Acts

P8 Security Assessment—Penetration Testing and Vulnerability Analysis

P9 Evaluation of Management Controls Over Encryption Methodologies

ISACA Professional Ethics

- ISACA Code of Professional Ethics

The Association's Code of Professional Ethics provides guidance for the professional and personal conduct of members of the Association and/or holders of the CISA and CISM designation

Kode Etik (1)

1. Mendukung implementasi standar, prosedur dan kontrol yang layak.
2. Melayani secara jujur, rajin dan tidak terlibat kegiatan melawan hukum
3. Menjaga kerahasiaan dari informasi yang didapatkan dari kegiatan audit, kecuali diinstruksikan oleh penegak hukum
4. Melaksanakan tugasnya secara objektif dan independen

Kode Etik (2)

5. Senantiasa tetap menjaga kompetensinya
6. Hanya bersedia melakukan tugas yang secara masuk akal bisa dikerjakan dengan profesional
7. Kehati-hatian dalam bertugas
8. Melaporkan hasil audit dengan baik, karena kalau ada fakta yang tidak disodorkan maka bisa menimbulkan kerugian

Kode Etik (3)

9. Mendukung edukasi kepada klien, direktur, manajemen, mitra kerja dan publik.
10. Menjaga profil sehingga tidak menimbulkan image buruk terhadap profesi auditor.

Definis: Analisa Resiko

- The potential that a given threat will exploit vulnerabilities of an asset or group of assets to cause loss or damage to the assets. The impact or relative severity of the risk is proportional to the business value of the loss/damage and to the estimated frequency of the threat.

Komponen Analisa Resiko

- Threats to, and vulnerabilities of, processes and/or assets (including both physical and information assets)
- Impact on assets based on threats and vulnerabilities
- Probabilities of threats (combination of the likelihood and frequency of occurrence)

Security components

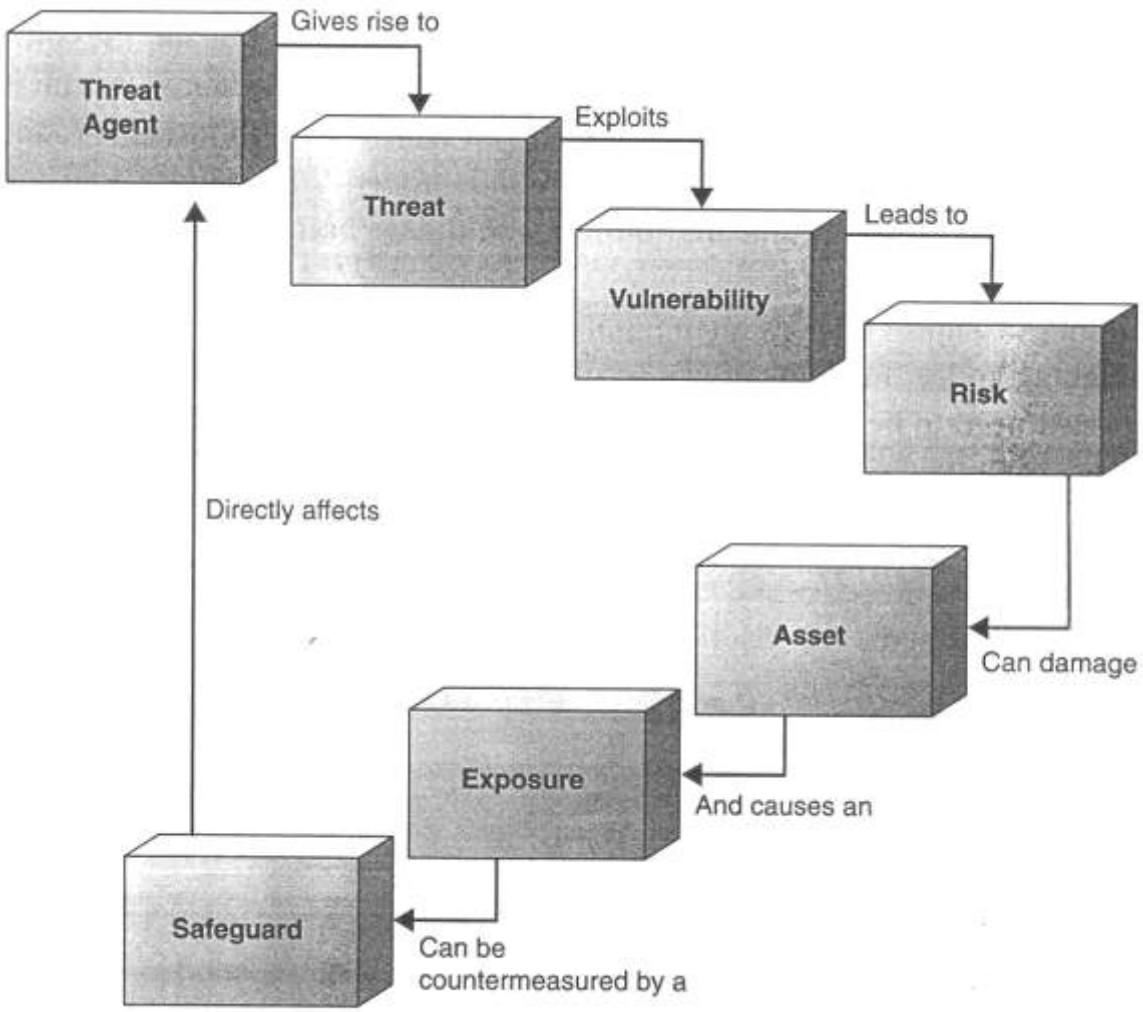


Figure 3-3 The relationships between the different security components

Business Risk

- Ujung-ujungnya ‘duit’
- Jadi seorang IS Auditor harus bisa menghubungkan suatu risk teknis kepada suatu business risk

Kalau ada resiko, lantas?

- Resiko diminimalisir → residual risk yang lebih kecil
- Resiko dicegah / dieliminasi
- Resiko ditransfer → asuransi
- Resiko diterima → karena resiko memangkecil

Manfaat Analisa Resiko

- Membantu auditor mengidentifikasi resiko dan ancaman terhadap suatu lingkungan sistem informasi → bisa membantu perencanaan audit
- Membantu penentuan tujuan audit
- Membantu risk-based audit

Qualitative Risk Modelling

Nilai Asset

Resiko (kemungkinan terjadi, kemungkinan kerugian per kasus, dll)

	Kecil	Sedang	Tinggi
Kecil			
Sedang			
Tinggi			

Fokuskan **AUDIT** mulai dari sini

Internal Controls (Kendali Internal)

- Internal control is a process put in place by the board of directors, senior management and all levels of personnel to provide reasonable assurance that an organization's business objectives will be achieved.

Controls

Controls : kebijakan, prosedur, praktek dan struktur organisasi yang dirancang untuk menjamin agar business objective dapat tercapai, sehingga kejadian-kejadian yang tak diingikan dapat dicegah dan diperbaiki.

Control Objectives

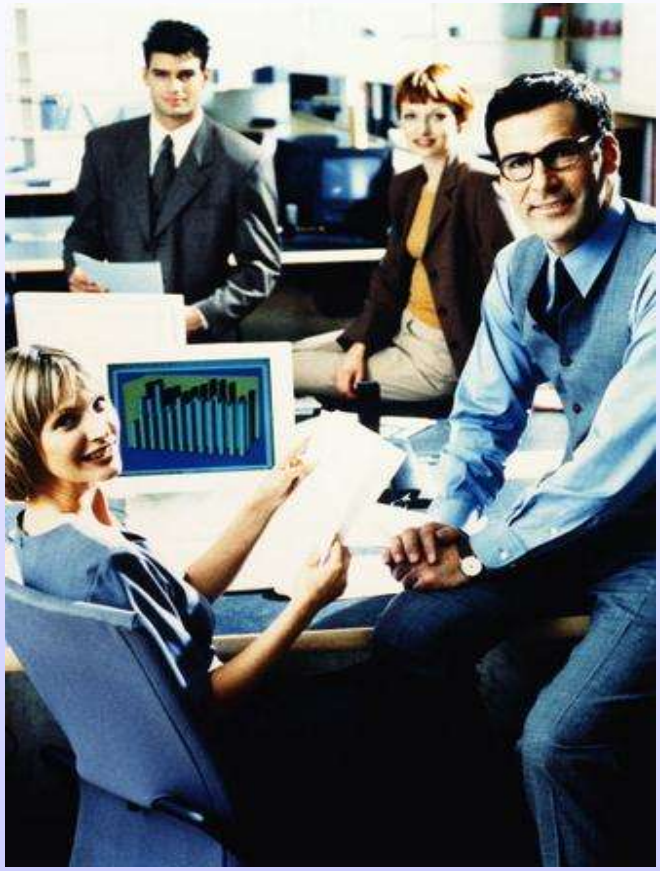
Control objectives : *"statement of the desired result, or purpose to be archived by implementing control procedurs in a particular activity"*

Controls & Control Objectives (3)

Control Objectives for Information and related Technology (CobitT) : dibuat oleh ISACF dan IT Governance Institute, dan dipublish oleh ISACA. Merupakan framwork 34 high-level control objectives. Di bawahnya ada 300 control objectives yang lebih detail.

Controls & Control Objectives (4)

Cobit dapat dimanfaatkan baik oleh auditor dan manager.

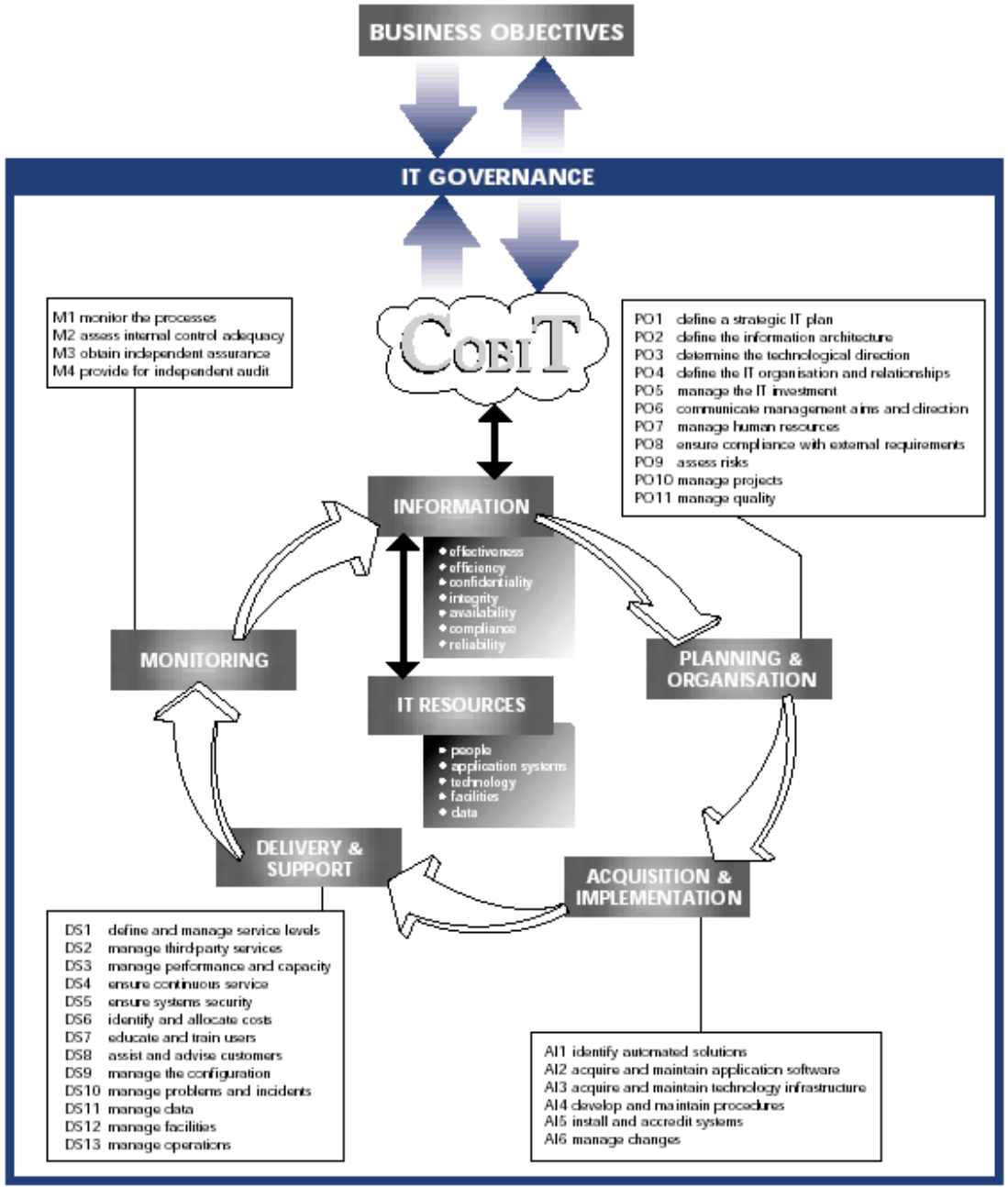


Controls & Control Objectives (5)

Contoh dari information systems control objectives :

1. Information on automated systems is secured from improper access
2. Each transaction is authorized and entered only once
3. All rejected transactions are reported.
4. Duplicate transactions are reported
5. Files are adequately backed up to allow for proper recovery

COBIT


BUSINESS OBJECTIVES
IT GOVERNANCE
CobiT
M1 monitor the processes
M2 assess internal control adequacy
M3 obtain independent assurance
M4 provide for independent audit
PO1 define a strategic IT plan
PO2 define the information architecture
PO3 determine the technological direction
PO4 define the IT organisation and relationships
PO5 manage the IT investment
PO6 communicate management aims and direction
PO7 manage human resources
PO8 ensure compliance with external requirements
PO9 assess risks
PO10 manage projects
PO11 manage quality
INFORMATION
effectiveness
efficiency
confidentiality
integrity
availability
compliance
reliability
MONITORING
PLANNING & ORGANISATION
IT RESOURCES
people
application systems
technology
facilities
data
DELIVERY & SUPPORT
ACQUISITION & IMPLEMENTATION
DS1 define and manage service levels
DS2 manage third-party services
DS3 manage performance and capacity
DS4 ensure continuous service
DS5 ensure systems security
DS6 identify and allocate costs
DS7 educate and train users
DS8 assist and advise customers
DS9 manage the configuration
DS10 manage problems and incidents
DS11 manage data
DS12 manage facilities
DS13 manage operations
AI1 identify automated solutions
AI2 acquire and maintain application software
AI3 acquire and maintain technology infrastructure
AI4 develop and maintain procedures
AI5 install and accredit systems
AI6 manage changes

Control Objectives for IT Governance - COBIT (1)

DOMAIN		PROCESS	Information Criteria							IT Resources				
			effectiveness	efficiency	confidentiality	integrity	availability	compliance	reliability	people	applications	technology	facilities	data
Planning & Organisation	PO1	Define a strategic IT plan	P	S						✔	✔	✔	✔	✔
	PO2	Define the information architecture	P	S	S	S					✔			✔
	PO3	Determine technological direction	P	S								✔	✔	
	PO4	Define the IT organisation and relationships	P	S						✔				
	PO5	Manage the IT investment	P	P					S	✔	✔	✔	✔	
	PO6	Communicate management aims and direction	P					S		✔				
	PO7	Manage human resources	P	P						✔				
	PO8	Ensure compliance with external requirements	P					P	S	✔	✔			✔
	PO9	Assess risks	P	S	P	P	P	S	S	✔	✔	✔	✔	✔
	PO10	Manage projects	P	P						✔	✔	✔	✔	
	PO11	Manage quality	P	P		P			S	✔	✔	✔	✔	
Acquisition & Implementation	AI1	Identify automated solutions	P	S							✔	✔	✔	
	AI2	Acquire and maintain application software	P	P		S		S	S		✔			
	AI3	Acquire and maintain technology infrastructure	P	P		S						✔		
	AI4	Develop and maintain procedures	P	P		S		S	S	✔	✔	✔	✔	
	AI5	Install and accredit systems	P			S	S			✔	✔	✔	✔	✔
	AI6	Manage changes	P	P		P	P		S	✔	✔	✔	✔	✔

Control Objectives for IT Governance - COBIT (2)

DOMAIN		PROCESS	Information Criteria							IT Resources				
			effectiveness	efficiency	confidentiality	integrity	availability	compliance	reliability	people	applications	technology	facilities	data
Delivery & Support	DS1	Define and manage service levels	P	P	S	S	S	S	S	✔	✔	✔	✔	✔
	DS2	Manage third-party services	P	P	S	S	S	S	S	✔	✔	✔	✔	✔
	DS3	Manage performance and capacity	P	P			S				✔	✔	✔	
	DS4	Ensure continuous service	P	S			P			✔	✔	✔	✔	✔
	DS5	Ensure systems security			P	P	S	S	S	✔	✔	✔	✔	✔
	DS6	Identify and allocate costs		P					P	✔	✔	✔	✔	✔
	DS7	Educate and train users	P	S						✔				
	DS8	Assist and advise customers	P	P						✔	✔			
	DS9	Manage the configuration	P				S		S		✔	✔	✔	
	DS10	Manage problems and incidents	P	P			S			✔	✔	✔	✔	✔
	DS11	Manage data				P			P					✔
	DS12	Manage facilities				P	P						✔	
	DS13	Manage operations	P	P		S	S			✔	✔		✔	✔
Monitoring	M1	Monitor the processes	P	P	S	S	S	S	S	✔	✔	✔	✔	✔
	M2	Assess internal control adequacy	P	P	S	S	S	P	S	✔	✔	✔	✔	✔
	M3	Obtain independent assurance	P	P	S	S	S	P	S	✔	✔	✔	✔	✔
	M4	Provide for independent audit	P	P	S	S	S	P	S	✔	✔	✔	✔	✔

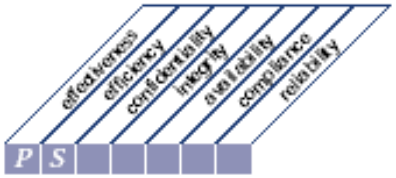
(**P**) primary (**S**) secondary (✔) applicable to

PO1 Planning & Organisation

Define a Strategic Information Technology Plan

COBIT

HIGH-LEVEL CONTROL OBJECTIVE



Control over the IT process of

defining a strategic IT plan

that satisfies the business requirement

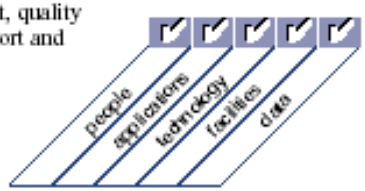
to strike an optimum balance of information technology opportunities and IT business requirements as well as ensuring its further accomplishment

is enabled by

a strategic planning process undertaken at regular intervals giving rise to long-term plans; the long-term plans should periodically be translated into operational plans setting clear and concrete short-term goals

and takes into consideration

- enterprise business strategy
- definition of how IT supports the business objectives
- inventory of technological solutions and current infrastructure
- monitoring the technology markets
- timely feasibility studies and reality checks
- existing systems assessments
- enterprise position on risk, time-to-market, quality
- need for senior management buy-in, support and critical review



CONTROL OBJECTIVES PO1

DETAILED CONTROL OBJECTIVES

1 DEFINE A STRATEGIC INFORMATION TECHNOLOGY PLAN

1.1 IT as Part of the Organisation's Long- and Short-Range Plan

CONTROL OBJECTIVE

Senior management is responsible for developing and implementing long- and short-range plans that fulfill the organisation's mission and goals. In this respect, senior management should ensure that IT issues as well as opportunities are adequately assessed and reflected in the organisation's long- and short-range plans. IT long- and short-range plans should be developed to help ensure that the use of IT is aligned with the mission and business strategies of the organisation.

1.2 IT Long-Range Plan

CONTROL OBJECTIVE

IT management and business process owners are

planning process include the organisational model and changes to it, geographical distribution, technological evolution, costs, legal and regulatory requirements, requirements of third parties or the market, planning horizon, business process re-engineering, staffing, in- or out-sourcing, data, application systems and technology architectures. Benefits of the choices made should be clearly identified. The IT long- and short-range plans should incorporate performance indicators and targets. The plan itself should also refer to other plans such as the organisation quality plan and the information risk management plan.

1.4 IT Long-Range Plan Changes

CONTROL OBJECTIVE

IT management and business process owners should ensure a process is in place to modify the IT long-range plan in a timely and accurate manner to accommodate changes to the organisa-

Detail control objective Card Center (1)

Control Objectives	Control Method / Procedures / Countermeasures
The preparation of PIN numbers should be rigidly controlled and secured	1. Never print PIN numbers on terminals & reports. 2. Make PINs available to only the customer and selected and identified bank security or data processing personnel. 3. Store PINs in an encrypted form. 4. Perform the PIN number preparation on the computer under dual control. 5. Use PIN mailers that are secured so that they do not reveal the printed PIN number. 6. Dan seterusnya.

Detail control objective Card Center (2)

Control Objectives	Control Method / Procedures / Countermeasures
Ensure that the generation of PINs is done in a secure environment and in a secure manner	1. Execute the generation of the actual PIN generation program under dual control 2. Schedule the execution of the PIN generation program randomly. The scheduled generation should be done only upon request and approval of authorized ATM and EFT personnel 3. Secure the documentation of the PIN algorithm and limit access to it.

Kategori Control: **Preventive**

- **Preventive**:
  - detect problem before they arise
  - pemantauan operasi dan input
  - melakukan prediksi atas problem yang mungkin terjadi
  - mencegah error dan tindakan kejahatan

- Misalnya:
  - pemisahan pekerjaan
  - ada prosedur yang tepat untuk proses otorisasi
  - menyediakan dokumen yang dirancang tepat bagi karyawan

Kategori Control: **Detective**

Detective :

Menggunakan kontrol untuk mendeteksi bahwa error, perubahan atau tindakan kejahatan (malicious) yang sudah terjadi, serta melaporkannya

Misalnya :

- Hash
- Kalkulasi ulang
- Internal audit
- Laporan kinerja sistem
- Check points dalam rantai produksi

Kategori Control: **Corrective**

Corrective:

- Meminimalisir dampak ancaman
- Mengidentifikasi sumber dari masalah
- Memperbaiki error dari sebuah masalah
- Mengubah sistem agar dapat meminimkan jumlah ancaman di masa depan

Misalnya:

- Contingency planning
- Backup
- Re-run

Definisi Audit

"Systematic process by which a competent, independent person objectively obtains and evaluates evidence regarding assertions about an economic entity or event for the purpose of forming an opinion about and reporting on the degree to which the assertion conforms to an identified set of standards."

General audit procedures

- Understanding of the audit area/subject
- Risk assessment and general audit plan
- Detailed audit planning
- Preliminary review of audit area/subject
- Evaluating audit area/subject
- Compliance testing
- Substantive testing
- Reporting(communicating results)
- Follow-up

Klasifikasi Audit

Kategori audit berdasarkan tujuannya :

1. Financial audit : mengetahui kebenaran dari laporan keuangan perusahaan
2. Operational audit : mengetahui ada/tidaknya, berfungsi/tidaknya interal controls dalam kegiatan operasi perusahaan
3. Administrative audit : mengetahui efisiensi produktifitas operasional dari sebuah perusahaan.
4. IS audit
5. Forensic audits: untuk menemukan atau menindaklanjuti suatu kejahatan
6. Specialized audit: misalnya dalam rangka SAS 70 (AICPA) dan atau SOX, melakukan audit terhadap internal controls

Tujuan Audit

Tujuan audit bisa sangat beraneka ragam, dan sangat tergantung keinginan manajemen atau peraturan yang mengharuskan audit.

Misalnya :

- Evaluasi terhadap internal controls
- Security audit
- Software Quality Assurance audit

Audit Methodology (1)

No.	Audit phase	Penjelasan
1.	Audit subject	Menentukan apa yang akan diaudit
2.	Audit objective	Menentukan tujuan dari audit. Misalnya: "menentukan apakah source code dapat diubah-ubah dalam data center yang dianggap secure"

Audit Methodology (2)

No.	Audit phase	Penjelasan
3.	Audit scope (ruang lingkup)	Menentukan sistem, fungsi dan bagian dari organisasi yang secara spesifik/khusus akan diaudit. Misalnya: "hanya melihat source code dari aplikasi Internet banking saja".
4.	Preaudit planning	Mengidentifikasi sumber daya dan SDM yang dibutuhkan. Menentukan dokumen-dokumen apa yang diperlukan untuk menunjang audit. Menentukan lokasi audit.

Audit Methodology (3)

No.	Audit phase	Penjelasan
5.	Audit procedures & steps for data gathering	Menentukan cara melakukan audit untuk memeriksa dan menguji kontrol. Menentukan siapa yang akan diwawancara.
6.	Evaluasi hasil pengujian dan pemeriksaan	Spesifik pada tiap organisasi

Audit Methodology (4)

No.	Audit phase	Penjelasan
7.	Prosedur komunikasi dengan pihak manajemen	Spesifik pada tiap organisasi
8.	Audit report preparationMenentukan bagaimana cara mereview hasil audit	Evaluasi kesahihan dari dokumen-dokumen, prosedur, dan kebijakan dari orgnisasi yang diaudit

Jenis Audit Risk (1)

Inherent risk : resiko yang dari *pada dasarnya* memang sudah ada pada auditee, karena nature (sifat) dari bisnis yang bersangkutan.

Misalnya :

- Kalkulasi 10.000 posting lebih bisa error ketimbang kalkulas 10 posting
- Uang kas lebih mudah tercuri ketimbang mobil di inventory

Jenis Audit Risk (2)

Control risk : suatu resiko yang signifikan yang mungkin muncul tak terdeteksi atau tak tercegah oleh kontrol internal.

Misalnya, di sebuah perusahaan besar, pemantauan piutang *aging* dilakukan secara manual oleh seorang pengawas interen. Control risk ini akan lebih kecil kalau menggunakan CAAT

Jenis Audit Risk (3)

Detection risk : resiko karena suatu ancaman tidak dideteksi karena auditor menggunakan teknik/prosedur yang kurang memadai.

Testing (1)

Compliance Testing

- Yakni test untuk menguji apakah kontrol diterapkan sesuai kebijakan dan prosedur organsasi.
- Tujuan utamanya adalah untuk menguji apakah kontrol-kontrol bekerja seperti yang diperkirakan dalam *preliminary evaluation*.
- Misalnya kontrol bahwa source code sama dengan executeables trakhir.

Testing (2)

Substantive Testing

- Menguji pengolahan sebenarnya.
- Substantive testing dapat dilakukan untuk mengecek apakah memang ada kesalahan dalam laporan keuangan (yang digenerate oleh komputer) atau kesalahan-kesalahaan lainnya.
- Auditor bisa melakukan substantive testing dengan cara mengambil sampel data, dan mengolahnya. Lalu memeriksa apakah valid.

Testing (3)

Korelasinya : kalau compliance testing menunjukkan banyak kesalahan, maka substantive testing hanya sedikit perlu dilakukan (vice versa).

Testing (4)

Cara memahami kontrol :

- Review system to identify controls
- Test compliance, apakah kontrol benar-benar bekerja
- Evaluasi kontrol, sebagai dasar perlu tidaknya substantive test

Risk Based Audit Approach

Gather Information & Plan

Aturan pemerintah, inherent risk, laporan keuangan, latar blkg perusahaan

Understand the Internal Controls

Prosedur kendali, analisa detection risk, analisa control risk

Compliance Test

Test policies, test segregation of duties

Substantive Test

Test account balances, test transactions

Conclude the Audit

Recommendations, reports

Evidence

Yakni informasi yang dipergunakan untuk menentukan apakah objek yang diaudit sesuai dengan kriteria atau control objectives tertentu.

Contoh Evidence (1)

1. Hasil observasi / pengamatan auditor: harus non-obtrusive. Misalnya:

- pola kerja pegawai
- struktur organisasi (bisa dengan melihat dokumen & interview)

2. Catatan interview: auditor harus tahu teknik interview.
3. Hasil korespondensi organisasi.

Contoh Evidence (2)

4. Dokumen-dokumen internal organisasi :

- feasibility study docs.
- test plans & reports.
- requirement docs.
- operations manual.
- quality assurance report.
- risk management document.
- Logs.

5. Hasil pengujian auditor.

Evidence Reliability

- Keindependensian dari yang menyediakan bukti : bukti dari luar organisasi sering lebih kuat, itulah sebabnya surat balasan bisa jadi dipergunakan untuk memeriksa account receivables.
- Kualifikasi orang yang memberikan bukti : Kalau interview harus pada orang yang tepat. Jangan tanya soal firewall ke janitor! Tetapi kecakapan auditor-pun juga dapat.
- Objektifitas dari sebuah bukti. perhitungan uang tunai lebih objektif ketimbang opini auditor hanya berdasarkan 1 orang responden yang diwawancarai mengenai perasaannya

Evidence

Auditor harus cari bukti-bukti yang relevan dan valid, sehingga bukti itu dapat dianggap 'competent'.

Sampling (1)

Sampling dipergunakan kalau waktu dan biaya tidak memungkinkan untuk memeriksa seluruh transaksi / kejadian dalam suatu populasi. Populasi adalah seluruh item yang harus diperiksa. Subset dar populasi disebut dengan istilah sampel. Sampling dipergunakan untuk menginferensi karakteristik dari populasi.

Sampling (2)

Pendekatan utama terhadap sampling:

1. Statistical sampling : sampel ditentukan secara objektif dengan kritera-kriteria yang khusus.
2. Non-statistical sampling : (judgemental sampling) menggunakan pertimbangan auditor dalam memilih sampel secar subjektif, sehingga cara ini sebenarnya mengandung resiko.

Sampling (3)

Jenis sampling lainnya :

1. Stop-or-go sampling: mencegah sampling yang terlalu banyak. Kalau terasa bahwa tidak akan ada error lagi (atau justru kebanyakan!) maka kegiatan audit boleh dihentikan.
2. Discovery sampling: metode sampling yang bisa dipergunakan untuk menemukan “jarum dalam tumpukan jerami”. Biasanya dipergunakan untuk mencari jejak korupsi, pemalsuan, penipuan dan tindakan melawan hukum lainnya.

Dua Jenis Sampling

- Attribute sampling: ada – tidak ada
- Variable sampling: Rp., nilai, besaran

Bagian dari Variable Sampling

- Stratified mean
- Unstratified mean
- Difference estimation

Computer-assisted audit techniques (CAAT)

- CAATs are a significant tool for IS auditors to gather information independently
- CAATs include:
  - Generalized audit software (ACL, IDEA, etc.)
  - Utility software
  - Test data
  - Application software for continuous online audits
  - Audit expert systems
  - Groupware & workflow management for auditors

Keuntungan CAAT

- Reduced level of audit risk
- Greater independence from auditee
- Broader audit coverage
- Faster audit process
- Improved exception identification
- Enhanced sampling
- Cost saving over time

Evaluasi Temuan Data (1)

- Dalam memberikan evaluasi terhadap bukti-bukti audit yang terkumpul, sangat tergantung dari pertimbangan auditor, terutama jenis-jenis bukti yang intangible (keterukurannya rendah).
- Semakin berpengalaman, maka akan semakin bijak.
- Ada cara lain yang lebih objektif? Menggunakan risk-based approach.

Evaluasi Temuan Data (2)

Biasanya dibuat juga *control matrix*, yang akan dilengkapi oleh auditor (bisa dengan skala lalu me-ranking), sehingga tahu di mana titik rawan dari organisasi/hal yang sedang di audit.

Evaluasi Temuan Data (3)

Auditor juga bisa menemukan kontrol yang kuat atau lemah. Bisa jadi untuk mengamankan suatu ATM, ternyata kunci pintu-nya tidak bisa dikunci dari dalam. Ini bisa jadi weak control. Tetapi dikompensasi oleh adanya satpam yang menunggu di samping ATM dan adanya video camera yang selalu on.

Evaluasi Temuan Data (4)

Catatan : biasanya 1 control objectives tidak terdiri dari 1 kontrol saja, tetapi lebih dari 1 kontrol yang saling mendukung.

Relativitas penting-tidaknya temuan

Sebuah temuan/evidence bisa penting untuk manager pada lapisan operasi, tetapi tidak penting bagi direksi.

Materiality

- An auditing concept regarding the importance of an item of information with regard to the impact/effect of the entity being audited
- An expression of relative significance of a particular matter in the context of the organization as a whole
- Sangat penting!

Struktur dan Isi laporan Audit (1)

Tidak ada yang baku, tetapi umumnya mencakup :

1. Pendahuluan: tujuan, ruang lingkup, lamanya audit, dan prosedur audit.
2. Kesimpulan umum dari auditor.
3. Hasil audit: apa yang ditemukan dalam audit, apakah prosedur dan kontrol layak atau tidak.
4. Rekomendasi.
5. Tanggapan dari manajemen (kalau perlu).
6. Dan sebagainya.

Struktur dan Isi laporan Audit (2)

Exit interview:

- interview terakhir antara auditor dengan pihak manajemen untuk membicarakan temuan-temuan dan rekomendasi tindak lanjut.
- Sekaligus meyakinkan tim manajemen bahwa hasil audit sahih.

Findings Report Form

Case reported by: (name of auditor)
Approved by: (name of lead auditor)
Reporting date:

Findings & evidence:

(example) We have found during the compliance test that there was no detaild formal requirement document nor detailed formal specification document during the software development process. This finding was also confirmed during the field interview with the users that participated in the software development process.

Evaluation based on control objectives, standard or best-practice:

(example) According to Pressman (1985) and ISACA (2005) there should always be a formal requirement & specification document before the software implementation begins.

Existing controls, countermeasures or procedures:

(example) Currently no controls exist to enforce the use of a formal software requirement & specification document.

Technical risk:

(example) Escalation of user requirements during software coding.

Materiality and business risk:

(example) We would rate this finding as a [very important, important, less important, not important], because:

- Inefficient use of budget due to over-estimation of the software size
- Miscalculation of software development time required, which might cause disruption to the overall system implementation schedule.

Recommended action:

(example) We recommend to PT.ABC to:

- always conduct a step process in software implementation. First, the development of a *detailed* and formal requirement & specification document prior to development. Second follows the actual software implementation, testing & deployment.
- Include the 2 step process in the tenders (one at a time).

Control Self Assessment

- Control self assessment (CSA) program objectives:
  - Enhancement of audit responsibilities (not a replacement)
  - Education for line management in control responsibility and monitoring
  - Concentration on areas of high risk
- IS auditor's role in CSAs
- Technology drivers
- Traditional vs. CSA approach

Traditional vs. CSA approach

Traditional	Control Self Assessment
Delegasikan tugas kepada bawahan	Empowered staff
Berdasarkan kebijakan yg ditetapkan dari atas	Continous improvement
Partisipasi pegawai terbatas	Partisipasi luas dari pegawai
Narrow stakeholder focus	Broad stakeholder focus
Auditors	All staffs, all levels

Corporate Governance

- Definisi OECD:
  "distribution of rights and responsibilities among different participants in the corporation, such as board, managers, and spells out the rules and procedures for making decisions on corporate affairs"
- Termasuk pula untu menentukan tujuan korporat, cara-cara untuk pencapaiannya, dan pemantauan kinerja korporat. Termasuk aturan untuk pelaporan resiko bisnis
- Membutuhkan perilaku etika korporat yang sehat mulai dari pemilik, komisaris, direksi sampai bawahan

IT Governance

- A set of responsibilities and practices used by an organization's management to provide strategic direction
- Ensure that goals are achievable.
- Risks are properly addressed
- Organizational resources are properly utilized

Sarbanes-Oxley Act 2002

Important paragraphs to notice

Section 302

Corporate Responsibility For Financial Reports

- The CEO and CFO of each issuer shall prepare a statement to accompany the audit report to certify the "*appropriateness of the financial statements and disclosures contained in the periodic report, and that those financial statements and disclosures fairly present, in all material respects, the operations and financial condition of the issuer.*"

Section 401(a):
Disclosures Required

- Each financial report that is required to be prepared in accordance with GAAP shall "*reflect all material correcting adjustments . . . that have been identified by a registered accounting firm . . . .*"

- The SEC shall issue rules providing that pro forma financial information must be presented so as not to "*contain an untrue statement*" or omit to state a material fact necessary in order to make the pro forma <u>financial information not misleading</u>.

Section 404:
Management Assessment Of Internal Controls

- Requires each annual report of an issuer to contain an "*internal control report*", which shall:
  - (1) state the responsibility of management for establishing and maintaining an adequate internal control structure and procedures for financial reporting; and
  - (2) contain an assessment, as of the end of the issuer's fiscal year, of the effectiveness of the internal control structure and procedures of the issuer for financial reporting.

Section 409:
Real Time Disclosure

- Issuers must disclose information on material changes in the financial condition or operations of the issuer on a rapid and current basis.

Section 1102:

Tampering With a Record or Otherwise Impeding an Official Proceeding

- Makes it a crime for any person to corruptly *alter, destroy, mutilate, or conceal* any document with the intent to *impair the object's* *integrity* *or* *availability* for use in an official proceeding or to otherwise obstruct, influence or impede any official proceeding is liable for up to 20 years in prison and a fine.

Title VIII:

Corporate and Criminal Fraud Accountability Act of 2002.

- It is a felony to "knowingly" destroy or create documents to "impede, obstruct or influence" any existing or contemplated federal investigation.